Chapter 11

Message Integrity and Message Authentication

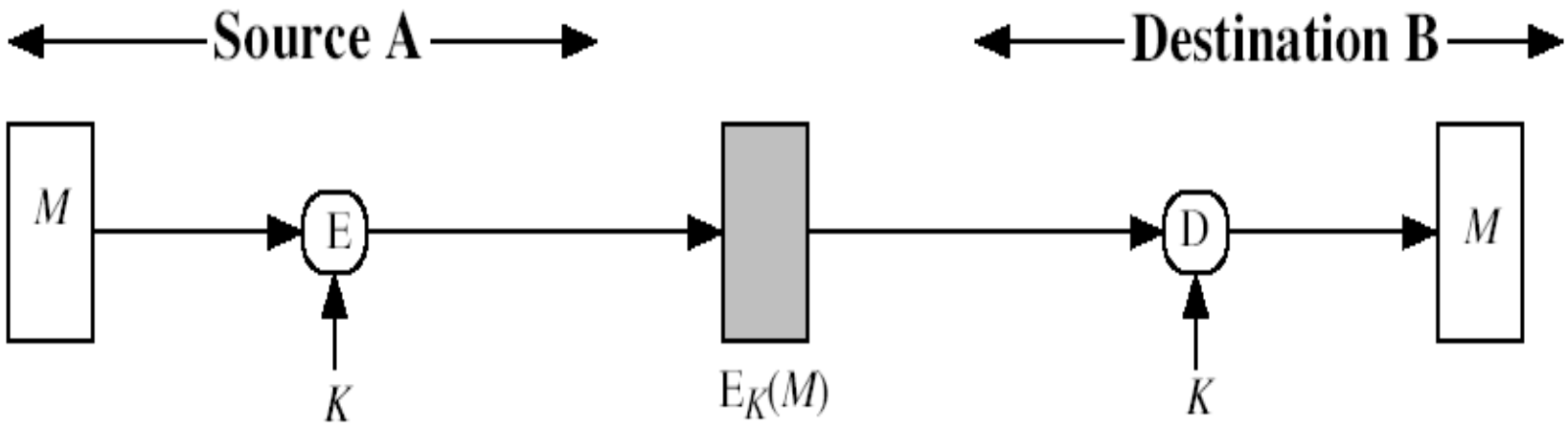
Copyright © The McGraw-Hill Companies, Inc. Permission required for reproduction or display.

Message Authentication

- message authentication is concerned with:
  - protecting the integrity of a message
  - validating identity of originator
  - non-repudiation of origin (dispute resolution)
- will consider the security requirements
- then three alternative functions used:
  - message encryption
  - message authentication code (MAC)
  - hash function

Message Encryption

- message encryption by itself also provides a measure of authentication
- if symmetric encryption is used then:
  - receiver know sender must have created it
  - since only sender and receiver now key used
  - know content cannot of been altered
  - if message has suitable structure, redundancy or a checksum to detect any changes



(a) Symmetric encryption: confidentiality and authentication

A → B: $E_K[M]$

- Provides confidentiality
  - Only A and B share K
- Provides a degree of authentication
  - Could come only from A
  - Has not been altered in transit
  - Requires some formatting/redundancy
- Does not provide signature
  - Receiver could forge message
  - Sender could deny message

(a) Symmetric encryption

Digital Signatures

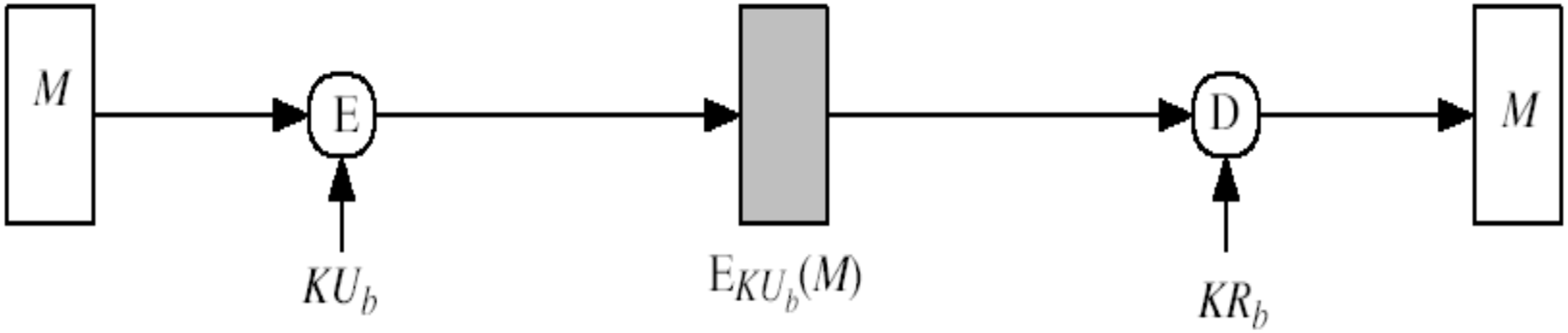
- have looked at message authentication
  - but does not address issues of lack of trust
- digital signatures provide the ability to:
  - verify author, date & time of signature
  - authenticate message contents
  - be verified by third parties to resolve disputes
- hence include authentication function with additional capabilities

Digital Signature Properties

- must depend on the message signed
- must use information unique to sender
  - to prevent both forgery and denial
- must be relatively easy to produce
- must be relatively easy to recognize & verify
- be computationally infeasible to forge
  - with new message for existing digital signature
  - with fraudulent digital signature for given message
- be practical save digital signature in storage

Message Encryption

- if public-key encryption is used:
  - encryption provides no confidence of sender
  - since anyone potentially knows public-key
  - however if
    - sender **signs** message using their private-key
    - then encrypts with recipients public key
    - have both secrecy and authentication
  - again need to recognize corrupted messages
  - but at cost of two public-key uses on message

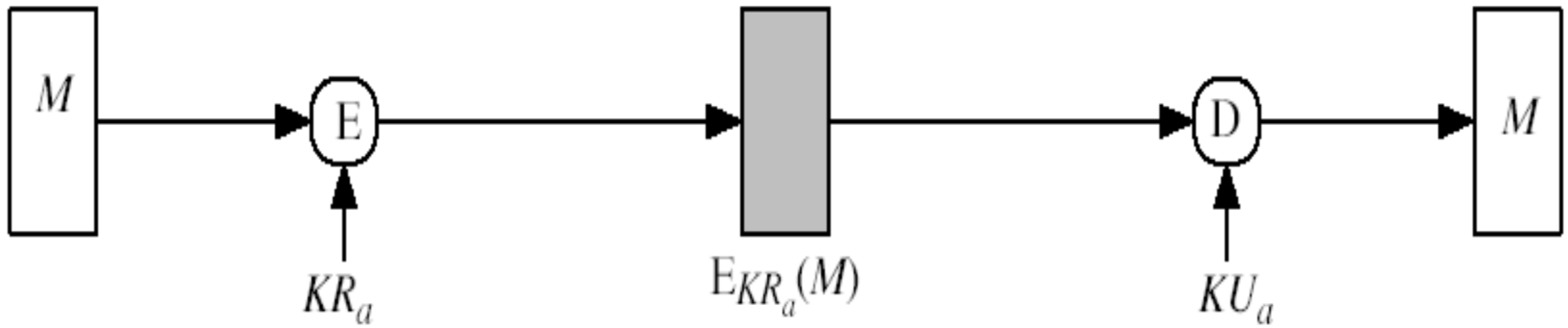


(b) Public-key encryption: confidentiality

A → B: $E_{KU_b}[M]$

- Provides confidentiality
  - Only B has KR_b to decrypt
- Provides no authentication
  - Any party could use KU_b to encrypt message and claim to be A

(b) Public-key encryption: confidentiality

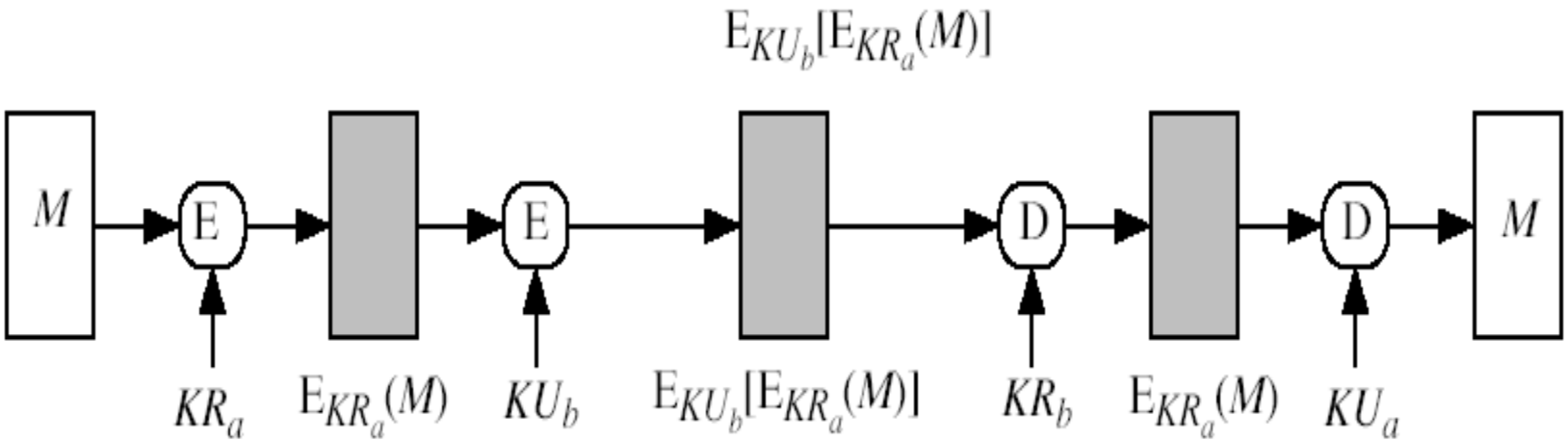


(c) Public-key encryption: authentication and signature

$A \rightarrow B: E_{KR_a}[M]$

- Provides authentication and signature
  - Only A has KR_a to encrypt
  - Has not been altered in transit
  - Requires some formatting/redundancy
  - Any party can use KU_a to verify signature

(c) Public-key encryption: authentication and signature



(d) Public-key encryption: confidentiality, authentication, and signature

---

$$A \rightarrow B: E_{KU_b}\left[E_{KR_a}(M)\right]$$

- Provides confidentiality because of KU_b
- Provides authentication and signature because of Kr_a

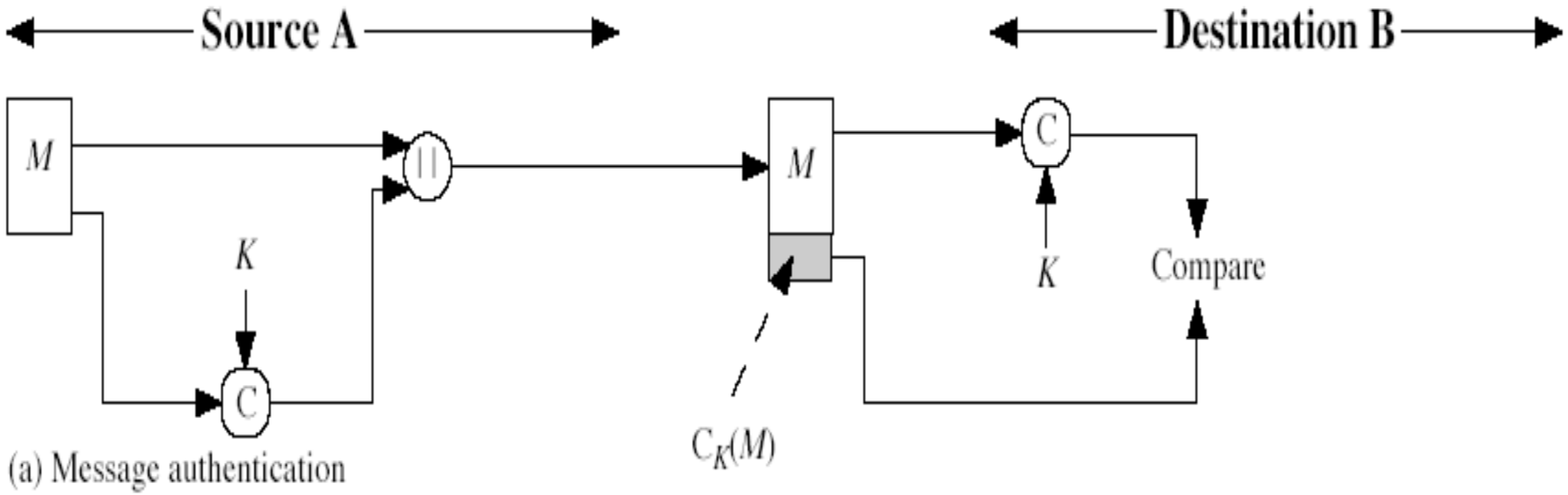
(d) Public-key encryption: confidentiality, authentication, and signature

Message Authentication Code (MAC)

- generated by an algorithm that creates a small fixed-sized block
  - depending on both message and some key
  - like encryption though need not be reversible
- appended to message as a **signature**
- receiver performs same computation on message and checks it matches the MAC
- provides assurance that message is unaltered and comes from sender

Message Authentication Codes

- as shown the MAC provides confidentiality
- can also use encryption for secrecy
  - generally use separate keys for each
  - can compute MAC either before or after encryption
  - is generally regarded as better done before
- why use a MAC?
  - sometimes only authentication is needed
  - sometimes need authentication to persist longer than the encryption (eg. archival use)
- note that a MAC is not a digital signature

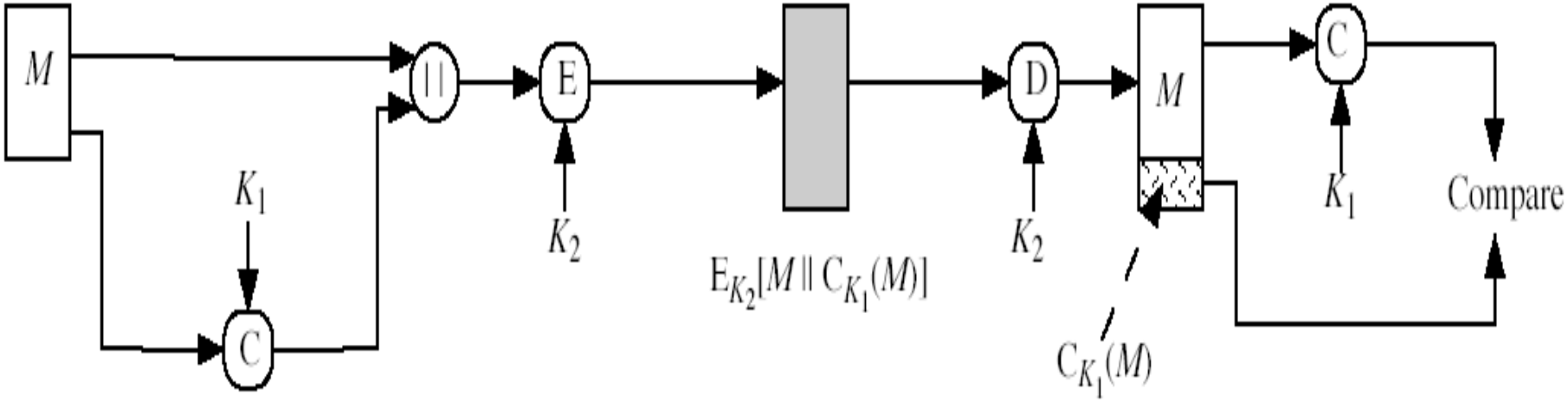


(a) Message authentication

$$A \rightarrow B: M \,||\, C_K(M)$$

- Provides authentication
  - Only A and B share K

(a) Message authentication



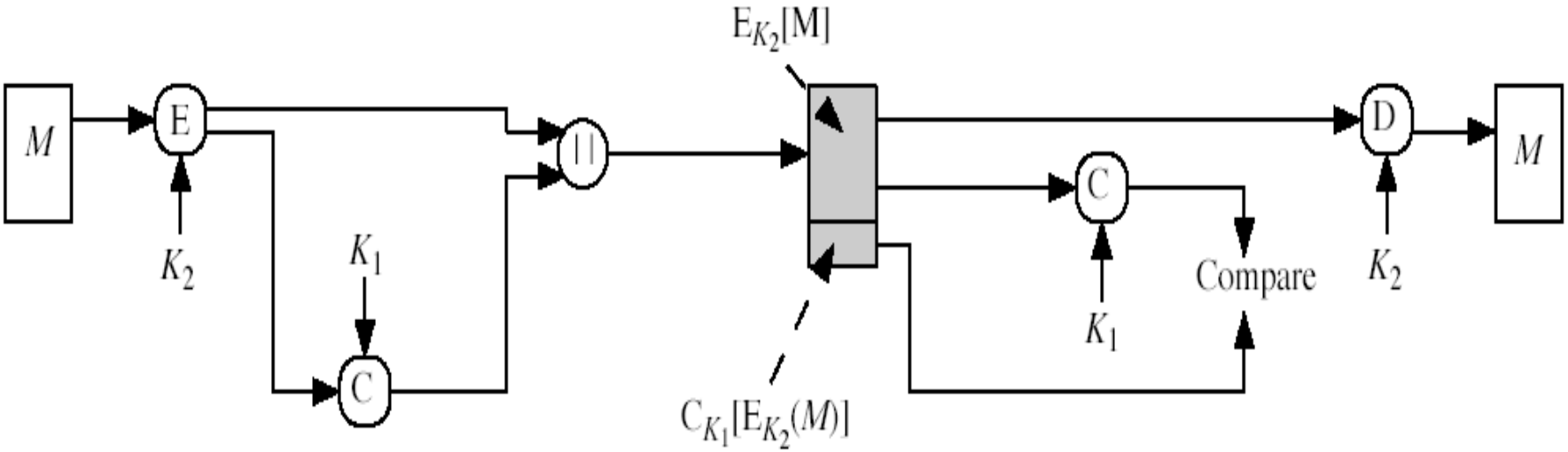
(b) Message authentication and confidentiality; authentication tied to plaintext

---

$$A \rightarrow B: \; E_{K_2}\left[M \;\|\; C_{K_1}(M)\right]$$

- Provides authentication
  - Only A and B share K_1
- Provides confidentiality
  - Only A and B share K_2

(b) Message authentication and confidentiality: authentication tied to plaintext



(c) Message authentication and confidentiality; authentication tied to ciphertext

$$A \rightarrow B: \; E_{K_2}[M] \,||\, C_{K_1}\left(E_{K_2}[M]\right)$$

- Provides authentication
  - Using K_1
- Provides confidentiality
  - Using K_2

(c) Message authentication and confidentiality: authentication tied to ciphertext

MAC Properties

- a MAC is a cryptographic checksum

  $MAC = C_K(M)$

  - condenses a variable-length message M
  - using a secret key K
  - to a fixed-sized authenticator
- is a many-to-one function
  - potentially many messages have same MAC
  - but finding these needs to be very difficult

Requirements for MACs

- taking into account the types of attacks
- need the MAC to satisfy the following:
  1. knowing a message and MAC, is infeasible to find another message with same MAC
  2. MACs should be uniformly distributed
  3. MAC should depend equally on all bits of the message

Using Symmetric Ciphers for MACs

- can use any block cipher chaining mode and use final block as a MAC
- **Data Authentication Algorithm (DAA)** is a widely used MAC based on DES-CBC
  - using IV=0 and zero-pad of final block
  - encrypt message using DES in CBC mode
  - and send just the final block as the MAC
    - or the leftmost M bits ($16 \leq M \leq 64$) of final block
- but final MAC is now too small for security

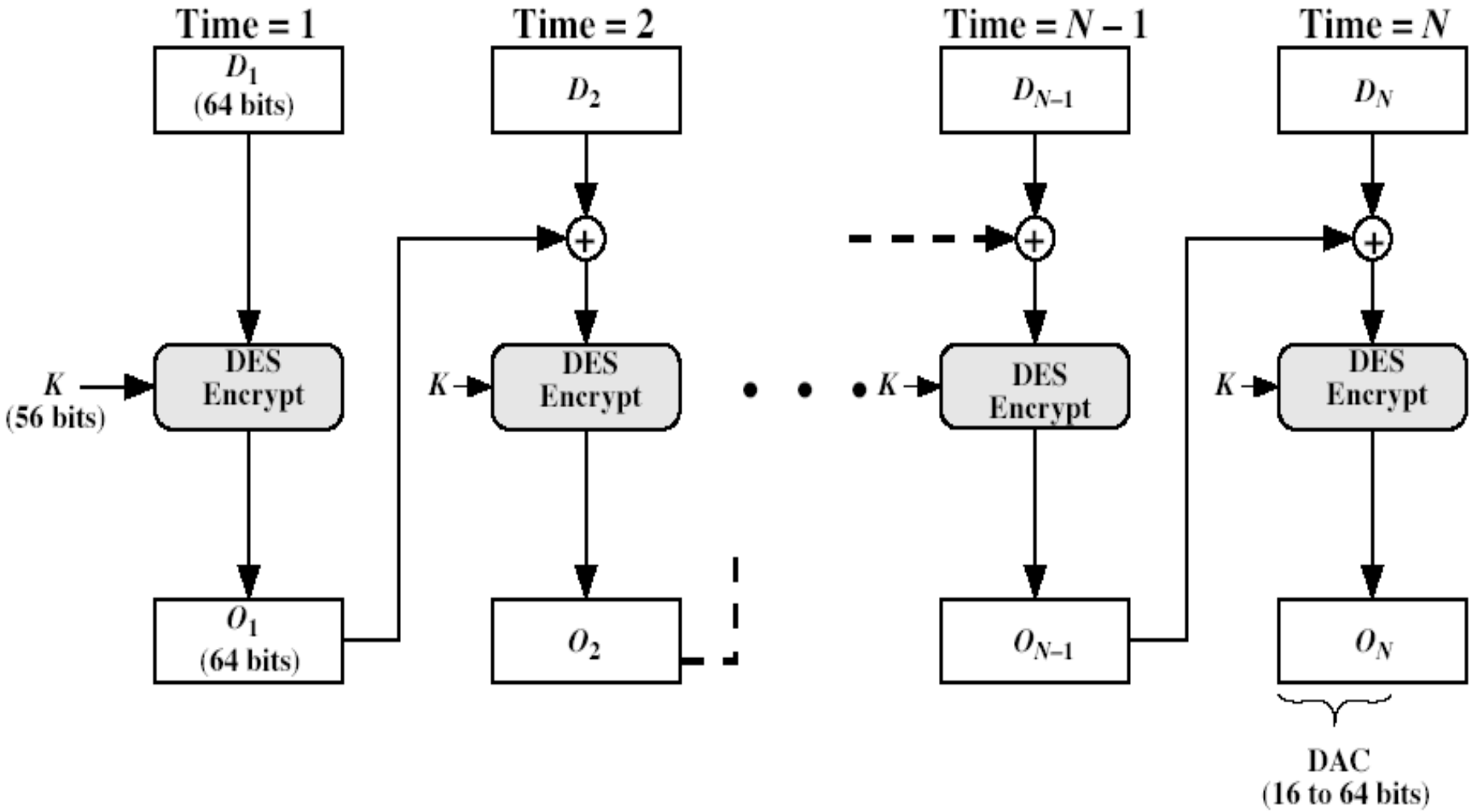


Figure 11.6 Data Authentication Algorithm (FIPS PUB 113)

Hash Functions

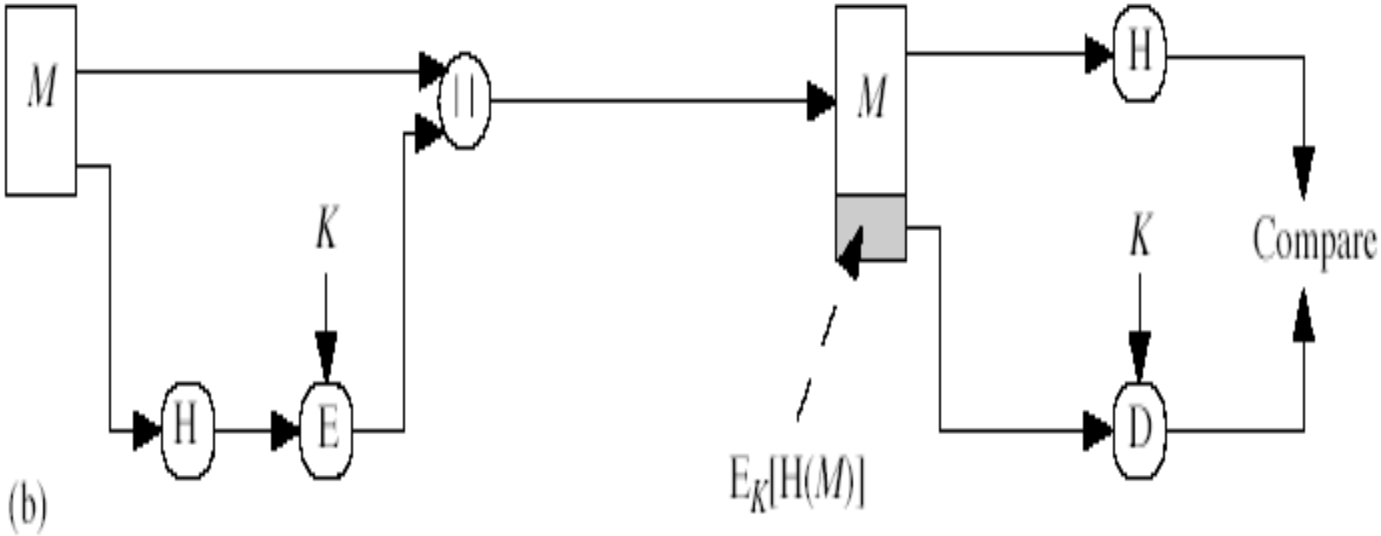
- condenses arbitrary message to fixed size
- usually assume that the hash function is public and not keyed
  - cf. MAC which is keyed
- hash used to detect changes to message
- can use in various ways with message
- most often to create a digital signature

Hash Function Properties

- a Hash Function produces a fingerprint of some file/message/data

  `h = H(M)`

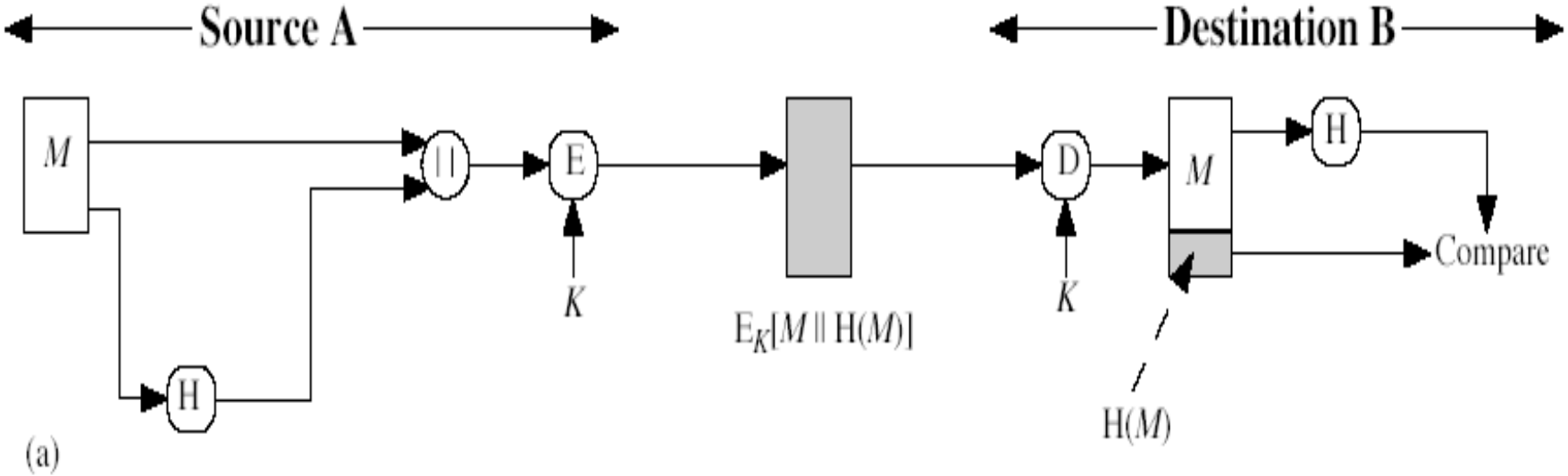
  - condenses a variable-length message M
  - to a fixed-sized fingerprint
- assumed to be public



$$A \rightarrow B: \; M \,||\, E_K\left[H(M)\right]$$

- Provides authentication
  - H(M) is cryptographically protected

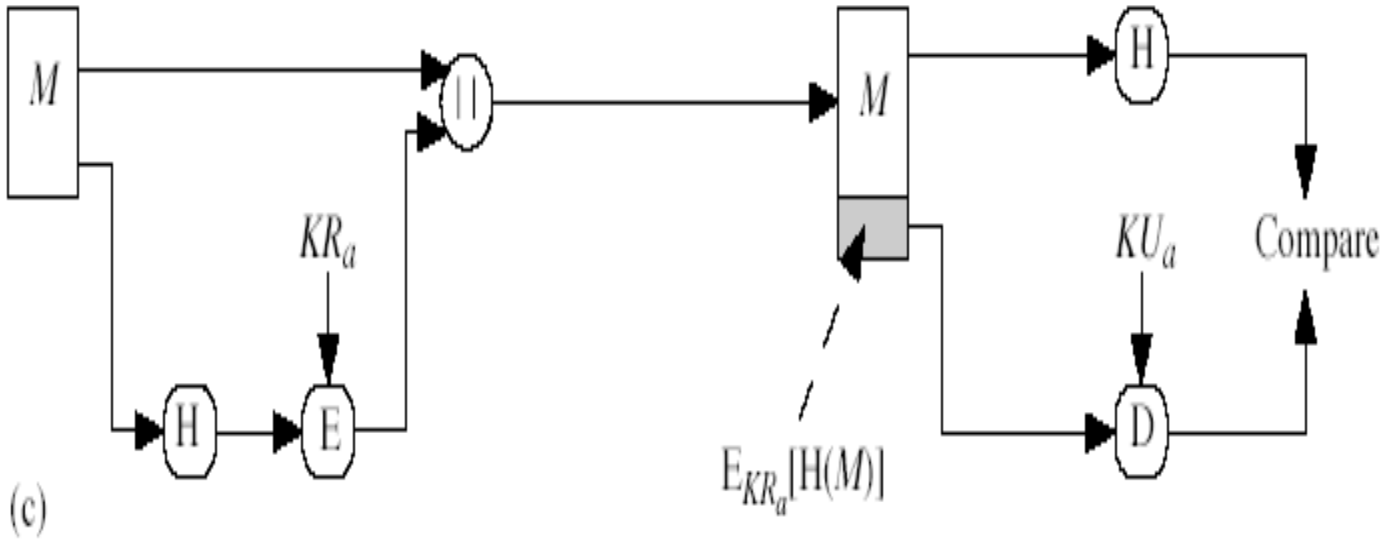
(b) Encrypt hash code - shared secret key



$$A \rightarrow B: E_K\left[M \parallel H(M)\right]$$

- Provides confidentiality
  - Only A and B share K
- Provides authentication
  - H(M) is cryptographically protected

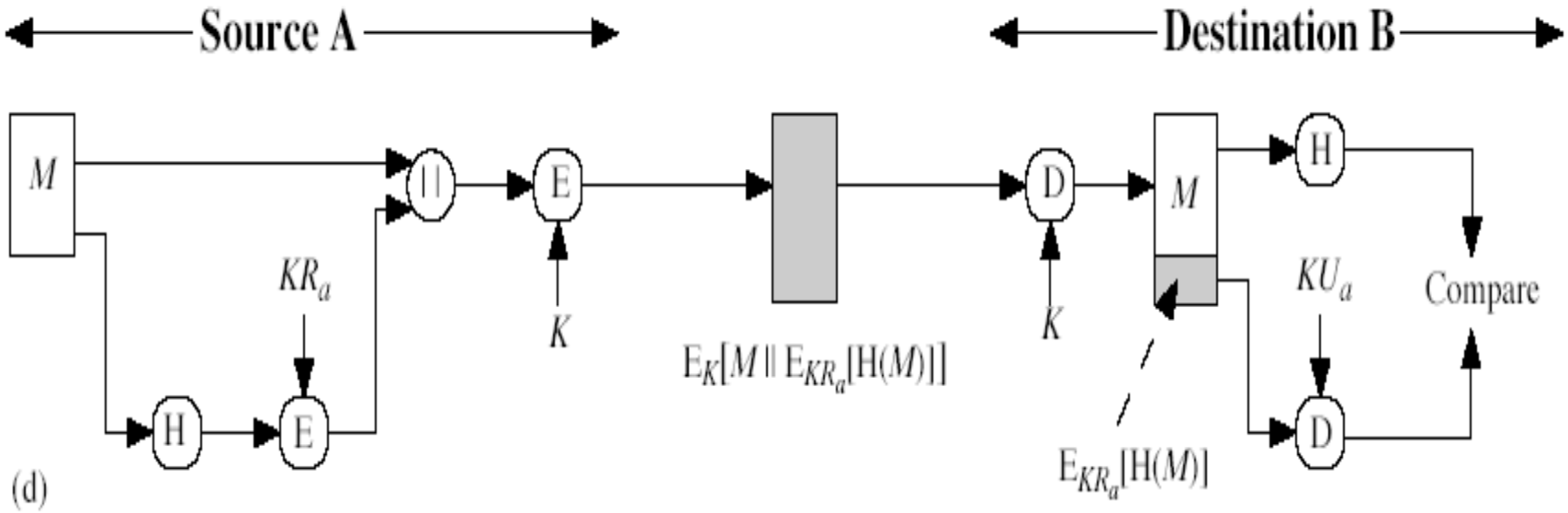
(a) Encrypt message plus hash code



$$A \rightarrow B: \; M \,||\, E_{KR_a}\left[H(M)\right]$$

- Provides authentication and digital signature
  - H(M) is cryptographically protected
  - Only A could create $E_{KR_a}\left[H(M)\right]$

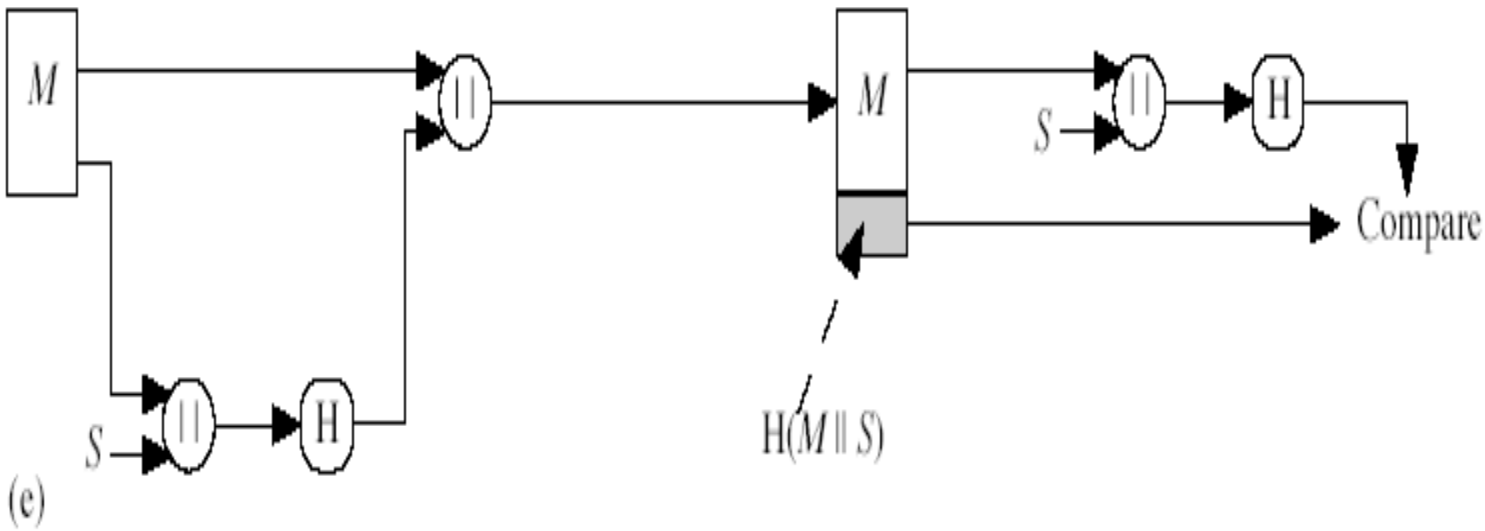
(c) Encrypt hash code - sender's private key



$$A \rightarrow B: \; E_K\left[M \,\|\, E_{KR_a}\left[H(M)\right]\right]$$

- Provides authentication and digital signature
- Provides confidentiality
  - Only A and B share K

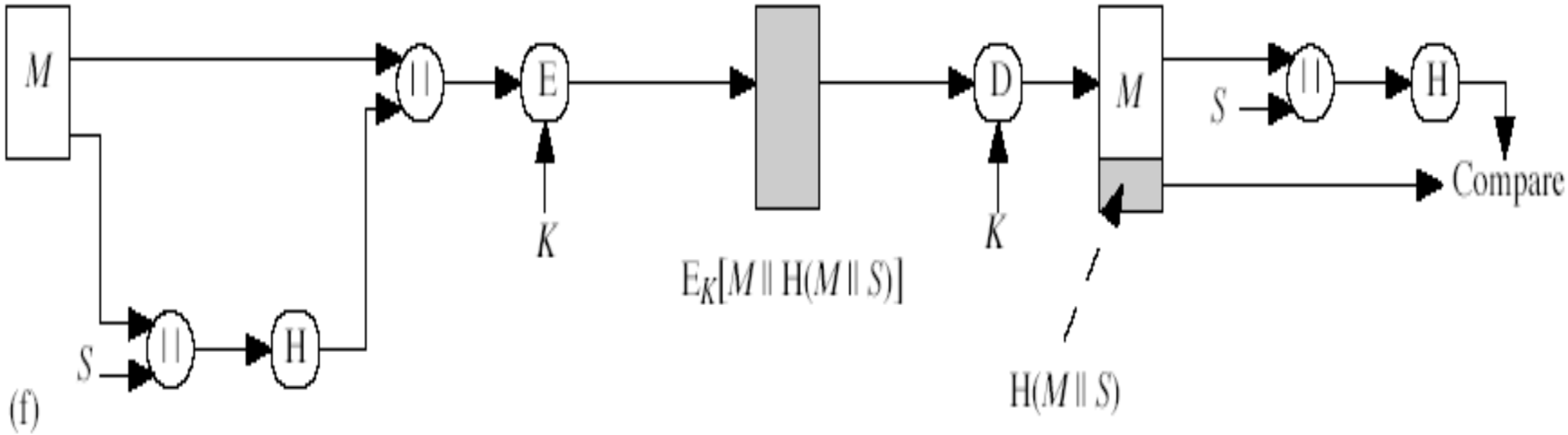
(d) Encrypt result of (c) - shared secret key



$$A \rightarrow B: M \parallel H(M \parallel S)$$

- Provides authentication
  - Only A and B share S

(e) Compute hash code of message plus secret value



$$A \rightarrow B: \; E_K\left[M \;\|\; H(M) \| S\right]$$

- Provides authentication
  - Only A and B share S
- Provides confidentiality
  - Only A and B share K

(f) Encrypt result of (e)

Requirements for Hash Functions

1. can be applied to any sized message `M`
2. produces fixed-length output `h`
3. is easy to compute `h=H(M)` for any message `M`
4. given `h` is infeasible to find `x` s.t. `H(x)=h`
   - one-way property
5. given `x` is infeasible to find `y` s.t. `H(y)=H(x)`
   - weak collision resistance
6. is infeasible to find any `x,y` s.t. `H(y)=H(x)`
   - strong collision resistance